# NEXTRISK AI

ENTERPRISE CYBERSECURITY PLATFORM (TRUVIA)

# Master Sprint Implementation Plan & Architecture Roadmap

A unified blueprint bridging Public Web Presence (Home, Solutions, Pricing, About, Contact) and Enterprise Cyber Operations (GRC, SOC, Penetration Testing & Predictive AI Decision Models).


PROJECT ARCHITECT & ENGINEERING LEAD

**Mohamed Shosha**

Lead Technical Architect & Systems Engineer



Document Version: 2.0.0 • Classification: Enterprise Confidential


MASTER ROADMAP

| 96 Tasks | 10 Sprints | 19 FRs | 31% Verified |
|---|---|---|---|
| GRANULAR SCOPE | PHASES 0 TO 9 | PUBLIC + APP | 74 TESTS PASSING |


© 2026 NextRisk AI Project • Mohamed Shosha


Stack: Spring Boot 3.3.5 • React 18 • MySQL 8 • Spring AI • Docker

# 1. Executive Summary & Platform Sitemap Architecture

Complete mapping of the Public Marketing Website, Authentication Gateway, and Core Cyber Application

PLATFORM OVERVIEW

## COMPLETE PLATFORM SITEMAP & USER NAVIGATION ARCHITECTURE

### 1. PUBLIC WEBSITE (VISITORS)

- `/` **Home Page** (Hero, Solutions, Risk Widget)
- `/services` **Services & Solutions** (GRC, SOC, AI)
- `/pricing` **Pricing Plans** (Tiers & Comparison)
- `/about` **About Us** (Mission & Leadership)
- `/contact` **Contact Us** (Inquiry & FAQ)
- `Modal` **Book a Demo** (Calendar scheduler)

### 2. AUTH GATEWAY

- `/login` **User Login** (JWT & Cookie)
- `/register` **Registration** (Validation)
- `/profile` **User Profile** (Active sessions)
- `/admin` **Admin Probe** (RBAC verify)
- `/403` **Forbidden Page**
- `/404` **Not Found Page**

### 3. ENTERPRISE CYBER WORKSPACE (PROTECTED)

- `/dashboard` **Executive CISO View** (Exposure & Posture)
- `/dashboard/soc` **SOC Live Telemetry** (Alert stream & MTTR)
- `/assets` **Asset Inventory** (Classification & Criticality)
- `/vulnerabilities` **Vulnerability Explorer** (Pentest ingestion)
- `/risks` **Central Risk Register** (5×5 Live Heatmap)
- `/compliance` **Frameworks & Controls** (ISO 27001, NIST)
- `/policies` **Policy Repository** (Versioning & Approval)
- `/incidents` **Incident Response** (Kanban & SLA timers)
- `/ai-assistant` **NextRisk AI Copilot** (Remediation playbooks)
- `/reports` **Board Reports** (PDF / CSV export)
- `/audit` **Immutable Audit Trail** (Activity logging)

**26 Tasks**
COMPLETED & VERIFIED
Phases 0 & 1 Fully Operational

**70 Tasks**
REMAINING SPRINTS
Phases 2 through 9 Roadmap

**Sprint 2**
IMMEDIATE MILESTONE
Public Website (Home, Services, Contact)

**74 Tests**
AUTOMATED GREEN TESTS
38 Backend / 36 Frontend

### NextRisk AI Dynamic Algorithmic Scoring Blueprint

```
Live Risk Score = [ (Asset Criticality × 0.35) + (CVSS v3 Base × 0.35) + (Threat Likelihood × 0.20) ] × (1 - Control Effectiveness × 0.70)
```

The core engine recalculates live risk scores whenever an asset tier, linked vulnerability, or compensating control is updated. The score is normalized from **1 to 100** and projected into financial exposure using the **FAIR (Factor Analysis of Information Risk)** model: `ALE = SLE × ARO` ($ USD).

# 2. Functional Requirements (FR) Traceability Matrix

Complete mapping of core platform capabilities (FR-WEB-01..05 and FR-01..14) to project personas and execution sprints.

REQUIREMENTS MATRIX

| ID | REQUIREMENT NAME | TARGET PERSONA | TARGET SPRINT | STATUS | ARCHITECTURAL SCOPE & DELIVERABLES |
|---|---|---|---|---|---|
| FR-WEB-01 | **Public Home & Landing Page** | Visitors / Prospects / All Users | Phase 2 (Sprint 2) | PLANNED | Modern public landing page with Hero section, security solutions overview, interactive risk simulator widget, live statistics, and registration CTAs. |
| FR-WEB-02 | **Services & Solutions Showcase Page** | Prospects / CISOs / Auditors | Phase 2 (Sprint 2) | PLANNED | Detailed public showcase of platform capabilities: GRC Automation, SOC Live Monitoring, Pentest Finding Linking, and AI-Powered Remediation. |
| FR-WEB-03 | **About Us & Architecture Page** | Visitors / Evaluators / Investors | Phase 2 (Sprint 2) | PLANNED | Company vision, cyber mission statement, technology stack overview (Spring Boot 3, React 18, MySQL 8, Spring AI), and engineering leadership. |
| FR-WEB-04 | **Contact Us & Demo Request Portal** | Clients / Prospective Users | Phase 2 (Sprint 2) | PLANNED | Interactive contact page with inquiry form, Book a Live Demo calendar scheduler, support contact channels, and interactive FAQ accordion. |
| FR-WEB-05 | **Pricing & Subscription Plans Page** | Prospective Clients / Buyers | Phase 2 (Sprint 2) | PLANNED | Transparent pricing tiers (Community, Professional, Enterprise) with monthly/annual billing toggle and full feature comparison matrix. |
| FR-01 | **Secure User Registration & Authentication** | All Users / Security Admin | Phase 1 (Sprint 1) | DONE — VERIFIED | Stateless JWT access tokens with rotating opaque refresh tokens, BCrypt hashing, HttpOnly SameSite=Strict cookies, and auto session restore. |
| FR-02 | **Centralized Risk Register** | GRC Analyst / CISO | Phase 4 (Sprint 4) | PLANNED | Single source of truth for cybersecurity risks: CRUD lifecycle, categorization, owner assignments, and risk treatment workflows. |
| FR-03 | **Dynamic Live Risk Scoring Engine** | GRC Analyst / SOC | Phase 4 (Sprint 4) | PLANNED | Algorithmic live scoring combining asset criticality, CVSS v3 findings, threat likelihood, and compensating control effectiveness into a normalized 1–100 score. |

| ID | REQUIREMENT NAME | TARGET PERSONA | TARGET SPRINT | STATUS | ARCHITECTURAL SCOPE & DELIVERABLES |
|---|---|---|---|---|---|
| FR-04 | **AI Risk Prediction & Intelligent Remediation** | Security Engineer / CISO | Phase 7 (Sprint 7) | PLANNED | Spring AI / LLM pipeline predicting probable attack paths from asset CVE telemetry and generating step-by-step remediation playbooks. |
| FR-05 | **Compliance Management & Controls** | Compliance Officer / GRC | Phase 5 (Sprint 5) | PLANNED | Multi-framework baseline compliance tracking for ISO/IEC 27001:2022, NIST CSF 2.0, and SOC 2 Type II with audit evidence tracking. |
| FR-06 | **Security Policy Management & Versioning** | GRC Analyst / Auditor | Phase 5 (Sprint 5) | PLANNED | Repository of internal security policies with document versioning, approval workflows (Draft -> Review -> Approved), and markdown preview. |
| FR-07 | **Vulnerability Reports & Pentest Ingestion** | Penetration Tester / SOC | Phase 3 (Sprint 3) | PLANNED | Automated ingestion and manual logging of vulnerability findings with CVSS v3 scoring parser and direct linking to affected business assets. |
| FR-08 | **Asset Inventory & Criticality Classification** | SOC Engineer / IT Admin | Phase 3 (Sprint 3) | PLANNED | Comprehensive asset catalog (Servers, Cloud, Web Apps, Databases) with classification tiering, data sensitivity, and business criticality weighting. |
| FR-09 | **Executive & Security Operations Dashboards** | CISO / SOC Analyst | Phase 8 (Sprint 8) | PLANNED | Dual-view dashboards: Executive CISO high-level view (financial exposure, compliance posture, top risks) and SOC live technical feed (open alerts, incident stream). |
| FR-10 | **Security Incident Management & Response** | SOC Analyst / Incident Lead | Phase 6 (Sprint 6) | PLANNED | End-to-end incident lifecycle state machine (Reported -> Triaged -> Containment -> Resolved) with SLA timers and containment audit log. |
| FR-11 | **Risk Prioritization Matrix & Heatmap** | GRC Analyst / Executive | Phase 4 (Sprint 4) | PLANNED | Interactive 5×5 dynamic risk heatmap (Likelihood vs. Impact) with drill-down capability and Business Impact Analysis (BIA) weighting. |
| FR-12 | **Role-Based Access Control (RBAC)** | Security Admin | Phase 1 (Sprint 1) | DONE — VERIFIED | Granular authorization with 5 seeded enterprise roles: ROLE_ADMIN, ROLE_CISO, ROLE_GRC_ANALYST, ROLE_SOC_ANALYST, ROLE_PENTESTER. |

| ID | REQUIREMENT NAME | TARGET PERSONA | TARGET SPRINT | STATUS | ARCHITECTURAL SCOPE & DELIVERABLES |
|---|---|---|---|---|---|
| FR-13 | **Notifications & Real-Time Alerts** | SOC Analyst / GRC Analyst | Phase 6 (Sprint 6) | PLANNED | In-app alert notification center with threshold triggers for high-risk breaches, SLA violations, and new critical vulnerability disclosures. |
| FR-14 | **Automated Executive & Compliance Reporting** | CISO / Compliance Auditor | Phase 8 (Sprint 8) | PLANNED | Automated generation and export of board-ready PDF executive summaries, compliance audit matrices, and CSV raw data exports. |

# 3. Master Sprint Execution Roadmap & Task Backlog

Granular engineering breakdown of all 96 project tasks across Phases 0 through 9 with explicit platform capabilities & deliverables.

96 DETAILED TASKS

SPRINT 0 (FOUNDATION) 100% COMPLETE & VERIFIED

## Phase 0: Monorepo & Environment Initialization

**Milestone Goal:** Establish containerized development environment, multi-tier project scaffolding, MySQL 8 with persistent volumes, and healthcheck orchestration.

| TASK ID | TASK TITLE & ACCEPTANCE CRITERIA | SUBSYSTEM | PRIO | EFFORT | STATUS | DEPENDENCIES |
|---|---|---|---|---|---|---|
| INFRA-001 | **Repository Architecture Scaffolding**<br>**Acceptance:** Created monorepo layout (backend/, frontend/, docker/, docs/). | DevOps | P0 | S | DONE | None |
| INFRA-002 | **MySQL 8 Containerization with Healthcheck**<br>**Acceptance:** Configured MySQL 8.0 container with mysqladmin ping healthcheck and persistent volumes. | Database | P0 | S | DONE | INFRA-001 |
| INFRA-003 | **Spring Boot 3.3.5 Backend Scaffolding**<br>**Acceptance:** Configured Java 21 / Maven project with Web, JPA, Security, Lombok, and Flyway dependencies. | Backend | P0 | M | DONE | INFRA-001 |
| INFRA-004 | **React 18 / Vite 5.4 Frontend Scaffolding**<br>**Acceptance:** Initialized modern React 18 SPA with Vite, React Router 6, Vitest, and testing library. | Frontend | P0 | M | DONE | INFRA-001 |
| INFRA-005 | **Full-Stack Docker Compose Orchestration**<br>**Acceptance:** Docker Compose wiring db:3306, backend:8080, and frontend:5173 with automatic service dependency. | DevOps | P0 | M | DONE | INFRA-002..004 |
| INFRA-006 | **Environment Templates & Validation**<br>**Acceptance:** Established .env.example templates and isolated secrets from version control. | Security | P0 | S | DONE | None |

### 🎯 WHAT THE PLATFORM DELIVERS & OUTPUTS AFTER SPRINT 0 (FOUNDATION)

At the conclusion of Sprint 0, the site provides a fully automated, containerized local hosting environment where frontend, backend, and database interact seamlessly via Docker Compose.

#### 🖥️ USER INTERFACE & PAGES

- Vite 5.4 dev server running at http://localhost:5173 with hot module reloading
- App shell baseline with route placeholders and automated Vitest suite (36 tests passing)
- Nginx reverse proxy container ready for production artifact bundling

#### ⚙️ BACKEND ENGINES & APIS

- Spring Boot 3.3.5 REST API running at http://localhost:8080 with Hikari connection pool
- MySQL 8.0 container running on ports 3306/3307 with automated mysqladmin healthchecks
- Flyway migration pipeline initialized and validating schema on startup

#### 💼 MILESTONE BUSINESS IMPACT

Zero-friction developer onboarding: any engineer can launch the entire platform stack locally with a single command (docker compose up) without manual database or environment setup.

SPRINT 1 (SECURITY MVP) 87% VERIFIED (20/23 DONE)

## Phase 1: Security Core, Authentication & RBAC MVP

**Milestone Goal:** Implement production-grade stateless JWT authentication, rotating opaque refresh tokens with theft-detection family revocation, Spring Security 6 filter chain, 5 RBAC roles, and modern React auth UI.

| TASK ID | TASK TITLE & ACCEPTANCE CRITERIA | SUBSYSTEM | PRIO | EFFORT | STATUS | DEPENDENCIES |
|---|---|---|---|---|---|---|
| DB-001 | **Flyway V1 & V2: Roles and Schema Seeding**<br>**Acceptance:** V1 base schema and V2 seed script for 5 enterprise RBAC roles. | Database | P0 | S | DONE | INFRA-002 |
| DB-002 | **Flyway V1: Users & User-Roles Tables**<br>**Acceptance:** Established users, roles, and user_roles junction tables with unique constraints. | Database | P0 | S | DONE | DB-001 |
| DB-003 | **Flyway V3: Refresh Tokens & Family Chain**<br>**Acceptance:** Created refresh_tokens table with token_hash, family_id, replaced_by, and revoked_at. | Database | P0 | S | DONE | DB-002 |
| BE-AUTH-001 | **User Self-Registration Endpoint**<br>**Acceptance:** POST /api/auth/register with BCrypt 10 password hashing and default role assignment. | Backend | P0 | M | DONE | DB-002 |
| BE-AUTH-002 | **User Login & Authentication Manager**<br>**Acceptance:** POST /api/auth/login validating credentials and returning short-lived JWT access token. | Backend | P0 | M | DONE | DB-002 |
| BE-AUTH-003 | **Stateless JWT Issuance & Nimbus Validation**<br>**Acceptance:** 15-minute HS256 JWT access tokens containing user ID, username, and role authorities. | Security | P0 | M | DONE | BE-AUTH-002 |
| BE-AUTH-004 | **Opaque Refresh Token Rotation & Theft Detection**<br>**Acceptance:** POST /api/auth/refresh rotating single-use refresh tokens; revokes entire family on replay. | Security | P0 | M | DONE | DB-003 |
| BE-AUTH-005 | **Server-Side Logout & Family Revocation**<br>**Acceptance:** POST /api/auth/logout revoking active refresh token family and clearing HttpOnly cookie. | Backend | P0 | S | DONE | BE-AUTH-004 |
| BE-AUTH-006 | **Current User Profile Endpoint (/api/auth/me)**<br>**Acceptance:** GET /api/auth/me returning authenticated user identity, email, and granted authorities. | Backend | P0 | S | DONE | BE-AUTH-003 |
| BE-AUTH-007 | **Spring Security 6 Stateless Filter Chain & CORS**<br>**Acceptance:** Stateless session creation, custom JwtAuthenticationFilter, and explicit CORS config. | Security | P0 | M | DONE | BE-AUTH-003 |
| BE-AUTH-008 | **RBAC Enforcement & Admin Probe (/api/admin/ping)**<br>**Acceptance:** @PreAuthorize('hasRole("ADMIN")') probe returning 200 OK for admin and 403 Forbidden for non-admin. | Backend | P0 | S | DONE | BE-AUTH-007 |

| TASK ID | TASK TITLE & ACCEPTANCE CRITERIA | SUBSYSTEM | PRIO | EFFORT | STATUS | DEPENDENCIES |
|---|---|---|---|---|---|---|
| BE-AUTH-009 | **Safe Bootstrap Admin Provisioning Engine**<br>**Acceptance:** Startup runner provisioning default system administrator with deterministic role wiring. | Security | P1 | S | DONE | BE-AUTH-002 |
| BE-AUTH-010 | **Automated Scheduled Expired Token Purging**<br>**Acceptance:** Purge method implemented in RefreshTokenService; requires @Scheduled cron activation. | Backend | P2 | S | PARTIAL | BE-AUTH-004 |
| FE-AUTH-001 | **Login Page & Form Validation**<br>**Acceptance:** React login screen with real-time field validation, error banners, and loading state. | Frontend | P0 | M | DONE | INFRA-004 |
| FE-AUTH-002 | **Register Page & Form Validation**<br>**Acceptance:** React registration screen with password confirmation, complexity checks, and redirect. | Frontend | P0 | M | DONE | INFRA-004 |
| FE-AUTH-003 | **Axios Client, Interceptors & Single-Flight Refresh**<br>**Acceptance:** Axios interceptor catching 401, queuing concurrent requests, and executing single refresh. | Frontend | P0 | M | DONE | FE-AUTH-001 |
| FE-AUTH-004 | **AuthContext Lifecycle & Auto Session Restore**<br>**Acceptance:** Context keeping token in memory, restoring session on reload via silent refresh. | Frontend | P0 | M | DONE | FE-AUTH-003 |
| FE-AUTH-005 | **Protected Route Guards & Role-Based Access**<br>**Acceptance:** ProtectedRoute redirecting unauthenticated users to /login and unauthorized to /403. | Frontend | P0 | S | DONE | FE-AUTH-004 |
| FE-AUTH-006 | **User Profile Page (/profile)**<br>**Acceptance:** User profile screen showing account metadata, role badges, and active session status. | Frontend | P1 | S | DONE | FE-AUTH-005 |
| FE-AUTH-007 | **Admin Access Verification Page (/admin)**<br>**Acceptance:** Admin verification dashboard probing /api/admin/ping and displaying RBAC status. | Frontend | P1 | S | DONE | FE-AUTH-005 |
| FE-AUTH-008 | **Responsive AppShell & Role-Aware Navigation**<br>**Acceptance:** Navigation sidebar and top header dynamically showing navigation links per role. | Frontend | P1 | M | DONE | FE-AUTH-005 |
| FE-AUTH-009 | **Self-Service Password Reset Workflow**<br>**Acceptance:** Email token verification and self-service password recovery flow. | Full-Stack | P2 | L | PLANNED | BE-AUTH-002 |
| FE-AUTH-010 | **Auth Portal Visual Polish / Redesign Realignment**<br>**Acceptance:** Visual alignment with high-fidelity corporate reference mockups. | Frontend | P2 | M | REVIEW | FE-AUTH-001 |

## 🎯 WHAT THE PLATFORM DELIVERS & OUTPUTS AFTER SPRINT 1 (SECURITY MVP)

> At the conclusion of Sprint 1, the platform features a complete, enterprise-grade authentication portal where users can register, log in, maintain secure sessions, and access role-restricted resources.

### 🖥️ USER INTERFACE & PAGES

- Live Login (/login) and Self-Registration (/register) portals with real-time validation and error banners
- Authenticated User Profile screen (/profile) displaying user identity, email, and assigned roles
- Admin RBAC Verification screen (/admin) showing live permission status against backend endpoints
- Role-tailored navigation sidebar and top bar automatically hiding/showing modules based on granted roles
- Client-side protected route guards (/routes/ProtectedRoute) preventing unauthorized access with /403 redirect

### ⚙️ BACKEND ENGINES & APIS

- Stateless JWT access token issuance (15-min lifetime) with Nimbus HMAC validation
- Single-use rotating refresh tokens stored in HttpOnly, SameSite=Strict cookies with replay theft detection
- Single-flight Axios interceptor queue preventing race conditions during concurrent token refreshes
- Role-Based Access Control enforcing 5 seeded roles: ADMIN, CISO, GRC_ANALYST, SOC_ANALYST, PENTESTER
- Automated system admin bootstrap runner initializing default root credentials safely

### 💼 MILESTONE BUSINESS IMPACT

Zero-trust user identity foundation. Protects all future business modules (risks, vulnerabilities, compliance) from unauthorized access, session hijacking, and brute-force token reuse.

SPRINT 2 (PUBLIC WEB PRESENCE) READY TO COMMENCE — HIGH PRIORITY

## Phase 2: Public Website, Marketing Portal & Landing Pages

**Milestone Goal:** Build the complete public-facing web experience that visitors see when visiting the domain: Home Page, Services, About Us, Pricing, Contact Us, and Demo Request.

| TASK ID | TASK TITLE & ACCEPTANCE CRITERIA | SUBSYSTEM | PRIO | EFFORT | STATUS | DEPENDENCIES |
|---|---|---|---|---|---|---|
| FE-NAV-001 | **Public Sticky Header & Responsive Navbar**<br>**Acceptance:** Navbar with Logo, navigation links, ThemeToggle, and 'Sign In' / 'Get Started' action buttons. | Frontend | P0 | M | PLANNED | INFRA-004 |
| FE-FOOT-001 | **Global Public Footer & Sitemap Component**<br>**Acceptance:** Footer with product links, company overview, newsletter signup, and copyright notice. | Frontend | P0 | S | PLANNED | INFRA-004 |
| FE-HOME-001 | **Home Page: Hero Section & Action CTAs**<br>**Acceptance:** Impactful Hero with cybersecurity badge, bold value statement, 'Start Free Trial' and 'Book Demo' CTAs. | Frontend | P0 | M | PLANNED | FE-NAV-001 |
| FE-HOME-002 | **Home Page: Core Security Solutions Grid**<br>**Acceptance:** 4 Interactive cards showcasing GRC, SOC, Pentest Ingestion, and Predictive AI with hover micro-animations. | Frontend | P0 | M | PLANNED | FE-HOME-001 |
| FE-HOME-003 | **Home Page: Interactive Live Risk Calculator Widget**<br>**Acceptance:** Client-side interactive widget letting visitors adjust sliders and preview live risk score calculation in real time. | Frontend | P1 | M | PLANNED | FE-HOME-002 |
| FE-HOME-004 | **Home Page: Metrics Counter & Testimonials**<br>**Acceptance:** Animated statistics bar (e.g. 70% Faster Audits, 99.9% Uptime) and executive quote carousel. | Frontend | P1 | S | PLANNED | FE-HOME-002 |
| FE-SERV-001 | **Dedicated Services & Solutions Page (/services)**<br>**Acceptance:** Comprehensive solutions page with deep dives into GRC automation, live SOC telemetry, and AI playbooks. | Frontend | P0 | M | PLANNED | FE-NAV-001 |
| FE-ABOUT-001 | **About Us & Leadership Page (/about)**<br>**Acceptance:** Mission, vision, technology stack badges, and Leadership Architect profile for Mohamed Shosha. | Frontend | P1 | M | PLANNED | FE-NAV-001 |
| FE-PRICE-001 | **Pricing & Subscription Plans Page (/pricing)**<br>**Acceptance:** 3-tier pricing cards (Community, Professional, Enterprise) with monthly/annual toggle and feature matrix. | Frontend | P1 | M | PLANNED | FE-NAV-001 |

| TASK ID | TASK TITLE & ACCEPTANCE CRITERIA | SUBSYSTEM | PRIO | EFFORT | STATUS | DEPENDENCIES |
|---|---|---|---|---|---|---|
| FE-CONT-001 | **Contact Us & Inquiry Form Page (/contact)**<br>**Acceptance:** Interactive contact form with real-time validation, business email checks, and direct support info. | Frontend | P0 | M | PLANNED | FE-NAV-001 |
| FE-DEMO-001 | **Book a Live Product Demo Modal & Scheduler**<br>**Acceptance:** Interactive modal allowing prospects to select date/time and request an architectural walkthrough. | Frontend | P1 | M | PLANNED | FE-CONT-001 |
| FE-FAQ-001 | **Interactive FAQ Accordion Component**<br>**Acceptance:** Smooth expandable accordion answering top questions regarding data privacy, compliance, and AI safety. | Frontend | P2 | S | PLANNED | FE-CONT-001 |

## 🎯 WHAT THE PLATFORM DELIVERS & OUTPUTS AFTER SPRINT 2 (PUBLIC WEB PRESENCE)

At the conclusion of Sprint 2, the website features a stunning, world-class public cyber marketing portal. Any visitor can explore platform solutions, test the interactive live risk simulator, view pricing tiers, read company background, and submit demo requests.

### 🖥️ USER INTERFACE & PAGES

- Public Sticky Navbar with brand crest, navigation links (Home, Services, Pricing, About, Contact), Theme Toggle, and 'Sign In / Register' CTAs
- Home Page (/) featuring Hero banner with dynamic cyber particle effects, feature showcases, and an Interactive Live Risk Simulator slider widget
- Services & Solutions Page (/services) breaking down GRC Automation, SOC Monitoring, Pentest Linking, and AI Remediation
- About Us Page (/about) detailing the mission, engineering philosophy, and leadership profile of Mohamed Shosha
- Pricing Plans Page (/pricing) featuring Community, Starter, and Enterprise tiers with a feature comparison checklist
- Contact Us & Demo Request Page (/contact) with interactive inquiry form, office location info, and interactive FAQ accordion
- Global Responsive Footer with sitemap links, social channels, newsletter subscription, and legal terms

### ⚙️ BACKEND ENGINES & APIS

- Contact Inquiry & Demo Request API (/api/public/contact) validating and logging prospect leads
- Newsletter Subscription API (/api/public/newsletter) storing email opt-ins
- Public System Status Probe (/api/public/status) providing live platform operational health metrics

### 💼 MILESTONE BUSINESS IMPACT

Transforms the technical backend repository into an attractive, customer-facing SaaS product that inspires confidence, clearly explains the platform value, and converts visitors into registered users.

SPRINT 3 (ASSET & VULN CORE) PLANNED

## Phase 3: Asset Inventory & Vulnerability Ingestion

**Milestone Goal:** Establish centralized asset repository with classification/criticality tiers, and implement vulnerability finding ingestion with CVSS v3 score parsing.

| TASK ID | TASK TITLE & ACCEPTANCE CRITERIA | SUBSYSTEM | PRIO | EFFORT | STATUS | DEPENDENCIES |
|---|---|---|---|---|---|---|
| DB-ASSET-001 | **Flyway V4: Asset Entity & Classification Schema**<br>**Acceptance:** Create assets table with name, type, classification (Public/Confidential/Restricted), and criticality (Low..Critical). | Database | P0 | M | PLANNED | DB-003 |
| DB-VULN-001 | **Flyway V5: Vulnerabilities & Findings Schema**<br>**Acceptance:** Create vulnerabilities table with CVE ID, CVSS v3 base score, severity, remediation status, and asset FK. | Database | P0 | M | PLANNED | DB-ASSET-001 |
| BE-ASSET-001 | **Asset Domain Entity, Repository & CRUD APIs**<br>**Acceptance:** Spring Boot REST controllers for listing, creating, updating, and archiving organization assets. | Backend | P0 | M | PLANNED | DB-ASSET-001 |
| BE-ASSET-002 | **Asset Criticality & Environment Tiering Engine**<br>**Acceptance:** Service logic computing asset business value weighting factor based on data classification and environment. | Backend | P1 | S | PLANNED | BE-ASSET-001 |
| BE-VULN-001 | **Vulnerability Entity, Repository & CRUD APIs**<br>**Acceptance:** REST endpoints for managing vulnerability findings, status tracking (Open/Fixed/Accepted), and asset associations. | Backend | P0 | M | PLANNED | DB-VULN-001 |
| BE-VULN-002 | **Pentest Report Ingestion & CVSS v3 Parser**<br>**Acceptance:** Service parsing JSON/CSV pentest reports (Nessus/Burp format) and auto-generating vulnerability records. | Backend | P1 | L | PLANNED | BE-VULN-001 |
| FE-ASSET-001 | **Asset Inventory Table with Multi-Filter Support**<br>**Acceptance:** Interactive React data table supporting filtering by asset type, environment, criticality, and search query. | Frontend | P0 | M | PLANNED | BE-ASSET-001 |
| FE-ASSET-002 | **Asset Creation / Edit Modal & Detail View**<br>**Acceptance:** Modal drawer with form validation for onboarding assets and viewing linked vulnerability findings. | Frontend | P1 | M | PLANNED | FE-ASSET-001 |
| FE-VULN-001 | **Vulnerability & Finding Explorer Dashboard**<br>**Acceptance:** Vulnerability explorer view with severity metric cards (Critical/High/Medium/Low) and filterable finding table. | Frontend | P0 | M | PLANNED | BE-VULN-001 |

| TASK ID | TASK TITLE & ACCEPTANCE CRITERIA | SUBSYSTEM | PRIO | EFFORT | STATUS | DEPENDENCIES |
|---|---|---|---|---|---|---|
| FE-VULN-002 | **Pentest Report Upload & Ingestion Wizard**<br>**Acceptance:** Drag-and-drop file uploader with schema validation, finding preview, and one-click bulk import. | Frontend | P1 | M | PLANNED | BE-VULN-002 |

### 🎯 WHAT THE PLATFORM DELIVERS & OUTPUTS AFTER SPRINT 3 (ASSET & VULN CORE)

At the conclusion of Sprint 3, the site delivers a searchable cyber asset inventory and a vulnerability ingestion portal that turns raw pentest files into actionable technical findings.

#### 🖥️ USER INTERFACE & PAGES

- Interactive Asset Inventory Catalog (/assets) with real-time search, environment filters (Prod/Staging/Dev), and criticality badges
- Asset Creation / Edit Modal Drawer allowing engineers to register new servers, web apps, databases, and cloud services
- Vulnerability Explorer Dashboard (/vulnerabilities) with metric cards showing Critical, High, Medium, and Low findings
- Pentest Ingestion Wizard allowing drag-and-drop file uploads (JSON/CSV) with live parsing preview and bulk import confirmation

#### ⚙️ BACKEND ENGINES & APIS

- RESTful Asset Management APIs (/api/assets) supporting CRUD operations with RBAC permission enforcement
- Asset Criticality Weighting Service calculating organizational impact factors based on data classification tier
- Vulnerability Finding CRUD APIs (/api/vulnerabilities) linking findings directly to affected asset entity IDs
- Automated CVSS v3 Parser ingesting raw scanner reports (Nessus, Burp Suite, OpenVAS) and normalizing vulnerability metrics

#### 💼 MILESTONE BUSINESS IMPACT

Eliminates shadow IT and fragmented vulnerability spreadsheets by creating an authoritative single-source inventory of all enterprise IT assets and their active vulnerabilities.

SPRINT 4 (RISK ENGINE) PLANNED

## Phase 4: Centralized Risk Register & Dynamic Scoring Engine

**Milestone Goal:** Build centralized cyber risk register, implement algorithmic live risk scoring model combining assets and vulnerabilities, and construct interactive 5×5 heatmap.

| TASK ID | TASK TITLE & ACCEPTANCE CRITERIA | SUBSYSTEM | PRIO | EFFORT | STATUS | DEPENDENCIES |
|---|---|---|---|---|---|---|
| DB-RISK-001 | **Flyway V6: Risk Register & Scoring Schema**<br>**Acceptance:** Create risks table with title, category, asset FK, inherent/residual scores, live_risk_score, and FAIR exposure ($). | Database | P0 | M | PLANNED | DB-VULN-001 |
| BE-RISK-001 | **Risk Entity, Repository & CRUD APIs**<br>**Acceptance:** REST controllers for full risk lifecycle management (Identify, Assess, Treat, Accept, Review). | Backend | P0 | M | PLANNED | DB-RISK-001 |
| BE-RISK-002 | **Dynamic Algorithmic Risk Calculation Engine**<br>**Acceptance:** Algorithmic engine: Score = [(Criticality * 0.35) + (CVSS * 0.35) + (Likelihood * 0.20)] * (1 - ControlEff * 0.70). | Backend | P0 | L | PLANNED | BE-RISK-001, BE-VULN-001 |
| BE-RISK-003 | **Financial Exposure Quantification (FAIR Model)**<br>**Acceptance:** FAIR framework computation: Annualized Loss Expectancy (ALE) = Single Loss Expectancy (SLE) * ARO ($ USD). | Backend | P1 | M | PLANNED | BE-RISK-002 |
| BE-RISK-004 | **Risk Prioritization Matrix Engine (5×5 Heatmap)**<br>**Acceptance:** Matrix aggregation service grouping active risks into 5×5 likelihood/impact coordinates with boundary thresholds. | Backend | P1 | M | PLANNED | BE-RISK-002 |
| FE-RISK-001 | **Centralized Risk Register Data Grid & Filtering**<br>**Acceptance:** Interactive risk register table with live risk score meter, category filters, owner tags, and status updates. | Frontend | P0 | M | PLANNED | BE-RISK-001 |
| FE-RISK-002 | **Interactive 5×5 Risk Heatmap Component**<br>**Acceptance:** Visual 5×5 colored grid component with risk count badges, click-to-filter interaction, and cell drill-down. | Frontend | P1 | M | PLANNED | BE-RISK-004 |
| FE-RISK-003 | **Risk Creation Wizard with Real-Time Score Preview**<br>**Acceptance:** Multi-step risk assessment modal calculating real-time risk score preview as the user adjusts parameters. | Frontend | P1 | M | PLANNED | BE-RISK-002 |

## 🎯 WHAT THE PLATFORM DELIVERS & OUTPUTS AFTER SPRINT 4 (RISK ENGINE)

At the conclusion of Sprint 4, the site delivers a full GRC Risk Register with real-time algorithmic risk scoring, an interactive 5×5 heatmap, and quantified financial loss estimation ($ USD).

### 🖥️ USER INTERFACE & PAGES

- Centralized Risk Register Grid (/risks) displaying risk ID, category, owner, inherent/residual scores, and live risk score meters
- Interactive 5×5 Risk Heatmap Component (Likelihood vs. Impact) with dynamic cell counters and click-to-filter drill-down
- Multi-Step Risk Assessment Wizard with real-time score preview slider responding immediately as parameters change
- Financial Risk Exposure Card displaying FAIR dollar quantification ($ USD) per risk and for the entire organization

### ⚙️ BACKEND ENGINES & APIS

- Algorithmic Dynamic Scoring Engine computing Live Risk Score (1–100) automatically on every asset/vulnerability update
- FAIR Framework Calculator quantifying Annualized Loss Expectancy (ALE = SLE * ARO) based on business criticality
- Risk Matrix Aggregation API grouping active risks into likelihood/impact coordinates with boundary color coding
- Event listener listening for vulnerability changes and recalculating affected organizational risk scores automatically

### 💼 MILESTONE BUSINESS IMPACT

Transforms abstract technical vulnerability metrics into quantified financial exposure that executive management and board members can immediately understand and prioritize.

SPRINT 5 (GRC & COMPLIANCE) PLANNED

## Phase 5: Compliance Management & Policy Governance

**Milestone Goal:** Implement multi-framework baseline compliance tracking (ISO 27001, NIST CSF, SOC 2), control assessment checklists, and security policy versioning.

| TASK ID | TASK TITLE & ACCEPTANCE CRITERIA | SUBSYSTEM | PRIO | EFFORT | STATUS | DEPENDENCIES |
|---|---|---|---|---|---|---|
| DB-COMP-001 | **Flyway V7: Frameworks, Controls & Assessment Schema**<br>**Acceptance:** Create compliance_frameworks, controls, and control_assessments tables with audit evidence attachments. | Database | P0 | M | PLANNED | DB-RISK-001 |
| DB-POL-001 | **Flyway V8: Policy Governance & Document Versioning**<br>**Acceptance:** Create security_policies and policy_revisions tables tracking version, review cycle, and approval state. | Database | P1 | M | PLANNED | DB-COMP-001 |
| BE-COMP-001 | **Framework Baseline Seeds (ISO 27001, NIST, SOC 2)**<br>**Acceptance:** Seed datasets containing ISO/IEC 27001:2022 clauses, NIST CSF 2.0 categories, and SOC 2 Trust Services Criteria. | Backend | P0 | M | PLANNED | DB-COMP-001 |
| BE-COMP-002 | **Compliance Score Calculation Engine (% Progress)**<br>**Acceptance:** Service aggregating control implementation status into percentage compliance score per framework. | Backend | P0 | M | PLANNED | BE-COMP-001 |
| BE-COMP-003 | **Control Assessment & Audit Evidence Upload API**<br>**Acceptance:** REST endpoints for assessing controls (Compliant/In-Progress/Non-Compliant) and uploading audit evidence files. | Backend | P1 | M | PLANNED | BE-COMP-001 |
| BE-POL-001 | **Security Policy Repository & Lifecycle Workflow**<br>**Acceptance:** REST APIs managing policy lifecycle state machine: DRAFT -> UNDER_REVIEW -> APPROVED -> RETIRED. | Backend | P1 | M | PLANNED | DB-POL-001 |
| BE-POL-002 | **Policy Document Versioning & Secure Storage**<br>**Acceptance:** Storage service managing version increments, change logs, and secure document attachments. | Backend | P2 | M | PLANNED | BE-POL-001 |
| FE-COMP-001 | **Compliance Posture Radial Gauges & Overview**<br>**Acceptance:** Compliance dashboard with radial progress meters for ISO 27001, NIST CSF, and SOC 2 posture. | Frontend | P0 | M | PLANNED | BE-COMP-002 |
| FE-COMP-002 | **Control Assessment Checklist & Evidence Modal**<br>**Acceptance:** Interactive checklist interface allowing auditors to update control statuses and view evidence. | Frontend | P1 | M | PLANNED | BE-COMP-003 |
| FE-POL-001 | **Security Policy Document Reader & Version History**<br>**Acceptance:** Markdown document reader displaying active corporate security policies with revision history timeline. | Frontend | P1 | M | PLANNED | BE-POL-001 |

## 🎯 WHAT THE PLATFORM DELIVERS & OUTPUTS AFTER SPRINT 5 (GRC & COMPLIANCE)

> At the conclusion of Sprint 5, the platform provides continuous compliance tracking across major frameworks and a policy governance repository with version history.

### 🖥️ USER INTERFACE & PAGES

- Compliance Posture Dashboard (/compliance) featuring radial progress gauges for ISO/IEC 27001, NIST CSF 2.0, and SOC 2 Type II
- Control Assessment Checklist allowing auditors to evaluate controls (Compliant, In-Progress, Non-Compliant) with evidence badges
- Audit Evidence Upload Modal allowing compliance teams to attach PDF/screenshot verification proofs to specific controls
- Security Policy Repository & Document Reader (/policies) displaying company policies in markdown with version change history

### ⚙️ BACKEND ENGINES & APIS

- Preloaded framework baseline seeds for ISO 27001:2022 clauses, NIST CSF categories, and SOC 2 Trust Criteria
- Automated Compliance Percentage Engine aggregating control statuses into real-time readiness scores
- Audit Evidence Storage Service handling secure file uploads, hashing, and link associations with controls
- Policy Lifecycle State Machine managing document status workflows (Draft -> Under Review -> Approved -> Retired)

### 💼 MILESTONE BUSINESS IMPACT

Replaces manual audit spreadsheets with continuous, real-time audit readiness, cutting external audit prep time by up to 70%.

SPRINT 6 (SOC OPERATIONS) PLANNED

## Phase 6: Security Incident Management & Workflow Automation

**Milestone Goal:** Build security incident triage board, state machine tracking containment SLAs, and automated alerting for critical risk threshold breaches.

| TASK ID | TASK TITLE & ACCEPTANCE CRITERIA | SUBSYSTEM | PRIO | EFFORT | STATUS | DEPENDENCIES |
|---|---|---|---|---|---|---|
| DB-INC-001 | **Flyway V9: Incidents, Timeline & Alerting Schema**<br>**Acceptance:** Create incidents, incident_timeline, and notification_events tables with severity and SLA deadlines. | Database | P0 | M | PLANNED | DB-RISK-001 |
| BE-INC-001 | **Incident Entity, Repository & State Machine**<br>**Acceptance:** REST controller and state machine enforcing transitions: REPORTED -> TRIAGED -> CONTAINMENT -> RESOLVED. | Backend | P0 | M | PLANNED | DB-INC-001 |
| BE-INC-002 | **Incident-to-Asset/Risk Correlation API**<br>**Acceptance:** Correlation service linking incoming security incidents directly to registered assets and open risks. | Backend | P1 | M | PLANNED | BE-INC-001, BE-RISK-001 |
| BE-NOTIF-001 | **Critical Risk Threshold Alert Dispatcher**<br>**Acceptance:** Event listener firing real-time notifications when a risk exceeds critical score threshold or incident SLA breaches. | Backend | P1 | M | PLANNED | BE-INC-001, BE-RISK-002 |
| FE-INC-001 | **Incident Triage Board (Kanban / List with SLAs)**<br>**Acceptance:** Kanban drag-and-drop / filterable list view showing active incidents, severity badges, and countdown timers. | Frontend | P0 | M | PLANNED | BE-INC-001 |
| FE-INC-002 | **Incident Timeline & Containment Audit Log Screen**<br>**Acceptance:** Detailed incident view showing root cause analysis, containment checklist, and chronological audit log. | Frontend | P1 | M | PLANNED | BE-INC-002 |
| FE-NOTIF-001 | **Real-Time Notification Center & Alert Banner**<br>**Acceptance:** Header notification bell with unread badge counter, alert dropdown, and toast notification popups. | Frontend | P1 | M | PLANNED | BE-NOTIF-001 |

## 🎯 WHAT THE PLATFORM DELIVERS & OUTPUTS AFTER SPRINT 6 (SOC OPERATIONS)

At the conclusion of Sprint 6, the site offers an operational SOC Incident Triage Center with SLA countdown clocks, containment audit logging, and in-app alert notifications.

### 🖥️ USER INTERFACE & PAGES

- Incident Triage Kanban Board (/incidents) organizing active cases across Reported, Triaged, Containment, and Resolved columns
- SLA Countdown Clocks with visual warning colors (Yellow/Red) alerting responders when breach windows approach
- Incident Detail View showing linked affected assets, risk severity, lead investigator assignment, and containment checklist
- Real-Time Notification Drawer in the header showing unread badge count, high-risk breach alerts, and dismiss controls

### ⚙️ BACKEND ENGINES & APIS

- Incident Lifecycle State Machine strictly enforcing legal investigation transitions and audit events
- Incident-to-Asset and Risk Correlation Engine mapping active attacks directly to registered infrastructure
- Critical Risk Alert Dispatcher firing asynchronous notifications whenever live risk scores breach critical thresholds
- Immutable Chronological Audit Timeline tracking every action taken during incident triage and containment

### 💼 MILESTONE BUSINESS IMPACT

Drastically reduces Mean Time to Detect (MTTD) and Mean Time to Respond (MTTR), ensuring organizational accountability and compliance with regulatory breach reporting windows.

SPRINT 7 (AI ENGINE) PLANNED

## Phase 7: AI-Powered Risk Prediction & Intelligent Remediation

**Milestone Goal:** Integrate Spring AI with LLM models for automated threat vector prediction, customized remediation playbook generation, and executive report synthesis.

| TASK ID | TASK TITLE & ACCEPTANCE CRITERIA | SUBSYSTEM | PRIO | EFFORT | STATUS | DEPENDENCIES |
|---|---|---|---|---|---|---|
| DB-AI-001 | **Flyway V10: AI Inferences & Playbook Caching**<br>**Acceptance:** Create ai_inferences and remediation_playbooks tables with prompt hashes and cached responses. | Database | P1 | M | PLANNED | DB-INC-001 |
| BE-AI-001 | **Spring AI / LLM Client Provider Integration**<br>**Acceptance:** Integrate Spring AI framework supporting OpenAI / Gemini / Ollama with token budgeting and retry resilience. | Backend | P1 | L | PLANNED | DB-AI-001 |
| BE-AI-002 | **Threat Vector Prediction Engine**<br>**Acceptance:** LLM reasoning service analyzing system asset combinations and open CVEs to predict likely attack paths. | Backend | P1 | L | PLANNED | BE-AI-001, BE-RISK-002 |
| BE-AI-003 | **Step-by-Step Remediation Playbook Generator**<br>**Acceptance:** Prompt engineering engine generating actionable engineering remediation steps for specific risks and CVEs. | Backend | P1 | L | PLANNED | BE-AI-001, BE-VULN-001 |
| BE-AI-004 | **Executive Summary Narrative Generator**<br>**Acceptance:** Automated generator synthesizing high-level narrative risk insights for CISO and board presentations. | Backend | P2 | M | PLANNED | BE-AI-001 |
| FE-AI-001 | **NextRisk AI Copilot Panel in Risk/Vuln Views**<br>**Acceptance:** Slide-over AI Assistant drawer allowing analysts to ask questions and generate remediation suggestions. | Frontend | P1 | M | PLANNED | BE-AI-003 |
| FE-AI-002 | **Remediation Action Plan Modal & Task Tracker**<br>**Acceptance:** Interactive modal displaying generated playbook steps with copyable CLI commands and completion checkboxes. | Frontend | P1 | M | PLANNED | FE-AI-001 |

## 🎯 WHAT THE PLATFORM DELIVERS & OUTPUTS AFTER SPRINT 7 (AI ENGINE)

At the conclusion of Sprint 7, the site features an intelligent AI Copilot that forecasts likely attack vectors and generates actionable, step-by-step remediation playbooks for active risks.

### 🖥️ USER INTERFACE & PAGES

- NextRisk AI Copilot Panel embedded as a slide-over drawer in both the Risk Register and Vulnerability Explorer views
- One-Click 'Generate Remediation Playbook' button producing customized mitigation procedures tailored to the asset stack
- Remediation Action Plan Modal featuring copyable CLI commands, configuration patches, and task completion checkboxes
- Predictive Threat Alerts Banner warning security teams of high-probability attack chains across connected assets

### ⚙️ BACKEND ENGINES & APIS

- Spring AI Integration Layer connecting to OpenAI / Gemini / Local LLMs with token budgeting and resilience retries
- Threat Vector Prediction Engine analyzing asset topologies and open CVE combinations to forecast breach paths
- Remediation Playbook Generation Service utilizing structured prompt templates to produce deterministic engineering fixes
- AI Inference Caching Layer avoiding redundant model invocations and storing generated recommendations in MySQL

### 💼 MILESTONE BUSINESS IMPACT

Multiplies security team efficiency by transforming raw vulnerability alerts into verified, copy-paste engineering remediation scripts in seconds instead of hours of manual research.

SPRINT 8 (EXECUTIVE INSIGHTS) PLANNED

## Phase 8: Executive & Security Dashboards + Reporting

**Milestone Goal:** Build CISO executive overview, real-time SOC operations feed, and automated board-ready PDF/CSV compliance report export.

| TASK ID | TASK TITLE & ACCEPTANCE CRITERIA | SUBSYSTEM | PRIO | EFFORT | STATUS | DEPENDENCIES |
|---|---|---|---|---|---|---|
| BE-DASH-001 | **Executive KPI Aggregation API (Org Risk, Exposure)**<br>**Acceptance:** REST endpoint providing aggregated metrics: Overall Score (0–100), Total Financial Exposure ($), MTTR. | Backend | P0 | M | PLANNED | BE-RISK-003, BE-COMP-002 |
| BE-DASH-002 | **SOC Operational Telemetry & Alert Stream API**<br>**Acceptance:** Live operational stream endpoint returning active alerts, affected assets, and critical open findings. | Backend | P1 | M | PLANNED | BE-INC-001 |
| BE-REP-001 | **Automated PDF / CSV Board Report Generator**<br>**Acceptance:** Backend service compiling executive summaries, risk registers, and compliance postures into downloadable PDF/CSV. | Backend | P1 | L | PLANNED | BE-DASH-001 |
| FE-DASH-001 | **Executive CISO Dashboard (Exposure, Posture, Trends)**<br>**Acceptance:** CISO dashboard featuring financial exposure gauge, top 5 critical risks, compliance dials, and trend graphs. | Frontend | P0 | L | PLANNED | BE-DASH-001 |
| FE-DASH-002 | **SOC Real-Time Operations Monitoring Feed**<br>**Acceptance:** Real-time SOC monitoring interface with live threat alerts, asset status indicators, and incident ticker. | Frontend | P1 | M | PLANNED | BE-DASH-002 |
| FE-REP-001 | **Instant Export & Board-Ready PDF Download UI**<br>**Acceptance:** One-click export modal allowing executives to download high-resolution board reports and raw audit spreadsheets. | Frontend | P1 | M | PLANNED | BE-REP-001 |

### 🎯 WHAT THE PLATFORM DELIVERS & OUTPUTS AFTER SPRINT 8 (EXECUTIVE INSIGHTS)

At the conclusion of Sprint 8, the platform delivers dual-view executive and operational dashboards, and one-click board-ready PDF report downloads.

#### 🖥️ USER INTERFACE & PAGES

- Executive CISO Dashboard (/dashboard/executive) featuring overall posture score, financial risk gauge ($ USD), top 5 risks, and trends
- SOC Real-Time Operational View (/dashboard/soc) with live telemetry stream, incident ticker, and asset health status indicators
- Instant Report Export Modal allowing users to generate and download comprehensive board reports and raw audit spreadsheets
- Interactive posture graphs and historical trend charts showing risk reduction trajectory over time

#### ⚙️ BACKEND ENGINES & APIS

- Executive KPI Aggregation Endpoint providing sub-second summary metrics for board presentations
- SOC Telemetry Stream API delivering real-time incident counters, Mean Time to Remediate (MTTR), and active alerts
- High-Resolution PDF / CSV Report Generation Service compiling charts, registers, and compliance statuses into downloadable files
- Role-based dashboard routing automatically landing CISOs on the executive view and SOC analysts on the operational view

#### 💼 MILESTONE BUSINESS IMPACT

Equips the CISO and executive leadership with crisp, financially quantified metrics for board meetings and regulatory filings, proving ROI on security investments.

SPRINT 9 (PRODUCTION READINESS) PLANNED

## Phase 9: System Hardening, Audit Logs & Production Readiness

**Milestone Goal:** Implement immutable activity audit logging, query optimization, rate limiting, asymmetric token signing, and automated CI/CD pipeline.

| TASK ID | TASK TITLE & ACCEPTANCE CRITERIA | SUBSYSTEM | PRIO | EFFORT | STATUS | DEPENDENCIES |
|---|---|---|---|---|---|---|
| DB-AUDIT-001 | **Flyway V11: Immutable Audit Trail Schema**<br>**Acceptance:** Create audit_logs table storing actor ID, action, entity type, entity ID, client IP, and before/after JSON diffs. | Database | P0 | M | PLANNED | DB-003 |
| BE-AUDIT-001 | **AspectJ Audit Logging Interceptor for Sensitive Ops**<br>**Acceptance:** AOP interceptor automatically recording all CUD actions across Risk, Asset, and Policy entities. | Backend | P0 | M | PLANNED | DB-AUDIT-001 |
| BE-PERF-001 | **Read Query Optimization, Index Tuning & Caching**<br>**Acceptance:** Composite indexing on risk score queries, Spring Cache abstraction for static framework seeds. | Backend | P1 | M | PLANNED | All DB tasks |
| SEC-HARD-001 | **IP/User Rate Limiting (Bucket4j / Nginx Limits)**<br>**Acceptance:** Rate limiting on /api/auth/login and /register (10 requests/minute per IP) to prevent brute-force attacks. | Security | P0 | M | PLANNED | BE-AUTH-002 |
| SEC-HARD-002 | **Asymmetric RS256/ES256 Token Signing & JWKS**<br>**Acceptance:** Upgrade token signing to RS256 with public JWKS endpoint (/oauth2/jwks) for decoupled verification. | Security | P2 | M | PLANNED | BE-AUTH-003 |
| QA-E2E-001 | **End-to-End Automated Browser Tests (Playwright)**<br>**Acceptance:** Automated browser test suite validating login, risk creation, heatmap click, and PDF export workflows. | QA | P1 | L | PLANNED | All FE/BE tasks |
| DEVOPS-CI-001 | **GitHub Actions Automated Build, Test & Lint CI/CD**<br>**Acceptance:** Automated GitHub Actions workflow running Maven verify, Vitest suites, Docker build, and lint checks. | DevOps | P1 | M | PLANNED | INFRA-005 |

## 🎯 WHAT THE PLATFORM DELIVERS & OUTPUTS AFTER SPRINT 9 (PRODUCTION READINESS)

At the conclusion of Sprint 9, the platform is fully production-hardened, featuring immutable audit logging, brute-force rate limiting, RS256 token verification, and automated CI/CD pipelines.

### 🖥️ USER INTERFACE & PAGES

- Audit Trail Explorer (/audit) displaying chronological system events, actor identity, IP address, and JSON before/after state diffs
- Rate Limiting Warning Banners gracefully notifying users when brute-force threshold attempts are exceeded
- Production-optimized, sub-second page transitions across both dark and light modes with zero layout shift
- Cross-browser and responsive mobile/tablet layout certification

### ⚙️ BACKEND ENGINES & APIS

- AspectJ Audit Interceptor automatically recording all create, update, and delete actions across all core domain entities
- Bucket4j In-Memory Token Bucket Rate Limiter protecting /api/auth/login and /register against brute-force attacks
- Asymmetric RS256 / ES256 Token Signing Architecture with public JWKS discovery endpoint (/oauth2/jwks)
- MySQL composite index optimization delivering sub-second response times across large-scale risk registers
- Automated GitHub Actions CI/CD Pipeline executing Maven test suites, Vitest frontend tests, and Playwright E2E browser tests

### 💼 MILESTONE BUSINESS IMPACT

Provides audit-proof compliance with strict legal and enterprise regulations, and guarantees system resilience, scalability, and automated zero-downtime releases.

# 4. Immediate Resumption Plan & Document Governance

Actionable restart checklist for Sprint 2 (Phase 2: Public Website & Marketing Portal) and formal sign-off.

EXECUTION STRATEGY

### Sprint 2 (Phase 2: Public Website & Landing Pages) — Immediate Execution Checklist

When active feature development begins, build the public website in the following strict sequential dependency order:

1. **Step 1 (FE-NAV-001 & FE-FOOT-001):** Build `PublicNavbar.jsx` with brand crest, navigation links (Home, Services, Pricing, About, Contact), ThemeToggle, and 'Sign In' / 'Get Started' buttons; and `PublicFooter.jsx` with complete sitemap and newsletter signup.
2. **Step 2 (FE-HOME-001 & FE-HOME-002):** Build `HomePage.jsx` with an impactful Hero banner, cybersecurity value proposition, and the 4 interactive solution cards (GRC, SOC, Pentest, AI).
3. **Step 3 (FE-HOME-003):** Implement the `InteractiveRiskSimulator.jsx` component on the Home Page, allowing prospective visitors to adjust sliders and preview live risk score calculation in real time.
4. **Step 4 (FE-SERV-001 & FE-PRICE-001):** Create `ServicesPage.jsx` detailing the platform's cybersecurity modules, and `PricingPage.jsx` with Community, Starter, and Enterprise tier cards with monthly/annual billing toggle.
5. **Step 5 (FE-ABOUT-001, FE-CONT-001 & FE-DEMO-001):** Build `AboutPage.jsx` featuring project leadership by Mohamed Shosha, `ContactPage.jsx` with validated inquiry form and FAQ accordion, and `BookDemoModal.jsx` for scheduling product walkthroughs.

### Document Approval & Architecture Sign-off

This document represents the master development specification and sprint backlog for NextRisk AI (TRUVIA).

PROJECT ARCHITECT & ENGINEERING LEAD

**Mohamed Shosha**

Lead Solutions Architect • NextRisk AI

STATUS & APPROVAL

**APPROVED**

Active Development Roadmap (v2.0.0)

RELEASE DATE

**October 2026**

Version 2.0.0